SIMATS ENGINEERING

ASSESSMENT TOOL 1 – REPORT ANALYSIS

COURSE NAME: Ethical Hacking
COURSE CODE: ITA1410

STUDENT NAME: K. Sri Lasya

REGISTER NUMBER: 192472216

QUESTION 1: ANALYSIS OF NMAP NETWORK SCAN REPORT

1.1 Introduction

Network security is an important component of cybersecurity because organizations depend on interconnected systems to store information, communicate, and provide services. Every network-connected system may expose services that require proper configuration and protection. If these services are not secured, attackers may attempt to gain unauthorized access, steal confidential information, disrupt operations, or compromise the entire system.

Ethical hacking is the authorized process of identifying and evaluating security weaknesses in computer systems, applications, and networks. Ethical hackers use techniques similar to those used by malicious attackers, but their objective is to identify weaknesses and recommend suitable preventive measures.

Network scanning is one of the initial activities performed during an authorized security assessment. It helps security analysts identify active systems, open ports, running services, operating system characteristics, and possible security weaknesses.

In the given scenario, a security analyst performed a network scan on the target system with IP address **192.168.1.10** using Nmap. The report identified open ports associated with HTTP, SSH, and MySQL. It also provided information about the operating system and service versions.

These findings indicate that the target system provides several network services that should be reviewed to determine whether they are necessary, appropriately configured, and protected against unauthorized access.

1.2 Objectives of the Analysis

The main objectives of analyzing the Nmap report are:

1. To identify the services running on the target system.
2. To understand the purpose of each open port.

3. To identify possible security risks associated with the detected services.
4. To explain how attackers might attempt to exploit weaknesses in these services.
5. To evaluate the importance of operating system and service-version detection.
6. To recommend appropriate security controls and preventive measures.
7. To develop a practical remediation strategy for improving the security of the target system.

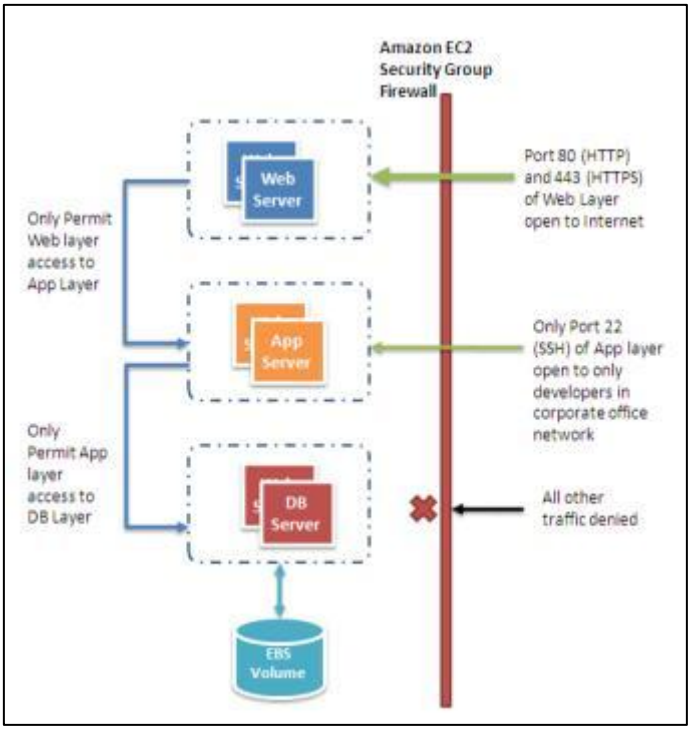


Figure 1.2: Network Security Architecture

1.3 Overview of Nmap

Nmap, which stands for Network Mapper, is an open-source tool widely used for network discovery and security auditing. It enables security professionals to determine which hosts are active on a network and which ports are accepting connections.

Nmap is useful for identifying network exposure and verifying whether security controls are functioning as intended.

1.3.1 Major Features of Nmap

Host discovery: Identifies systems that are reachable within a specified network.

Port scanning: Determines which TCP or UDP ports are open, closed, or filtered, depending on the scanning method and network configuration.

Service detection: Attempts to identify services running on open ports.

Version detection: Helps determine the software or service version running on a target.

Operating system detection: Estimates the operating system using characteristics of network responses.

Security auditing: Supports authorized assessments that identify unnecessary network exposure and potential weaknesses.

1.3.2 Importance of Network Scanning

Network scanning helps organizations maintain an inventory of network-accessible services. It also supports vulnerability management, firewall validation, asset discovery, and incident investigation.

For example, a server intended only to host a website may not require direct remote administration from every network. A scan that identifies an unnecessarily exposed SSH service may prompt the security team to restrict administrative access.

Similarly, a database server should generally accept connections only from authorized application servers or administrative systems. If a database port is accessible from untrusted networks, the organization should investigate whether the exposure is necessary.

However, an open port does not automatically indicate a vulnerability. The actual security risk depends on the software version, configuration, authentication requirements, network exposure, and sensitivity of the data being handled.

1.4 Interpretation of the Nmap Report

The scan identified three important services on the target system.

Port	Service	Main Function	Primary Security Concern
22	SSH	Remote administration	Unauthorized login and outdated software
80	HTTP	Web communication	Unencrypted traffic and web application vulnerabilities
3306	MySQL	Database access	Unauthorized access and data exposure

The findings should be interpreted as an initial indication of the target's network exposure rather than proof that the system has already been compromised.

1.4.1 Port 22 – SSH

SSH is used to establish encrypted remote connections to systems. It is commonly used by administrators to manage servers, execute commands, transfer files, and perform maintenance.

Although SSH provides encryption, the security of the service depends on the implementation and configuration. Weak passwords, excessive privileges, outdated software, and unrestricted access can increase risk.

1.4.2 Port 80 – HTTP

HTTP is used to transfer web pages and application data between a web server and a client. Standard HTTP does not encrypt the communication.

If sensitive information is transmitted through HTTP over an untrusted network, an attacker with an appropriate position on the communication path may be able to observe or modify the traffic.

The web application may also contain weaknesses involving input validation, session management, authentication, or access control.

1.4.3 Port 3306 – MySQL

MySQL is a relational database management system used to store structured information. It may contain user details, application records, transactions, or other business information.

Exposing MySQL to unnecessary networks increases the opportunity for unauthorized connection attempts. The impact of a successful compromise depends on the privileges of the compromised account and the information stored in the database.

1.5 Security Risk Assessment

The severity of a security risk depends on three major factors:

- **Likelihood:** The probability that a weakness will be exploited.
- **Impact:** The potential damage if exploitation succeeds.
- **Exposure:** The extent to which the service is reachable by unauthorized users.

For the given report, a preliminary qualitative assessment is presented below.

Finding	**Potential Impact**	**Initial Priority**
SSH accessible on port 22	Unauthorized administrative access	Medium to High
HTTP accessible on port 80	Web attacks or information exposure	Medium to High
MySQL accessible on port 3306	Database compromise or data loss	High if unnecessarily exposed

Outdated software versions, if confirmed	Exploitation of known vulnerabilities	Depends on the specific vulnerability

These priorities are preliminary. They must be adjusted after confirming whether the services are exposed to trusted or untrusted networks, whether vulnerabilities exist, and how sensitive the affected assets are.

1.6 Detailed Analysis of SSH – Port 22

1.6.1 Purpose of SSH

Secure Shell is a protocol used for secure remote administration. It encrypts the communication between a client and a server and supports authentication of connecting users.

Administrators use SSH to maintain Linux servers, configure applications, transfer files, and troubleshoot system problems. Because SSH may provide command-line access, an improperly protected service can become a significant security concern.

1.6.2 Security Weaknesses Associated with SSH

Weak passwords: Passwords that are short, predictable, or reused across systems may be vulnerable to guessing or credential-stuffing attempts.

Outdated implementations: Unsupported or unpatched SSH software may contain vulnerabilities that could allow unauthorized activity under particular conditions.

Excessive privileges: If remote users have administrative privileges unnecessarily, a compromised account may cause greater damage.

Unrestricted network access: Allowing SSH connections from all networks increases the number of systems that can attempt to connect.

Poor authentication monitoring: If failed logins are not monitored, repeated attempts may continue without timely detection.

Compromised private keys: SSH keys that are stolen, shared, or stored insecurely may be misused to access systems.

1.6.3 Possible Attack Scenarios

Scenario 1: Password-Guessing Attack

An attacker who can reach the SSH service may repeatedly attempt to authenticate using guessed credentials. If the organization permits weak passwords and lacks rate limiting or monitoring, an account may be compromised.

The attacker could then access files, execute commands, or attempt to obtain additional privileges, depending on the account's permissions.

Scenario 2: Exploitation of Outdated Software

An attacker may identify the SSH implementation and version, then investigate whether that version has a known vulnerability.

If the affected version is vulnerable and the required conditions are present, exploitation may lead to unauthorized access or service disruption.

Version detection alone does not confirm exploitability. The analyst must verify the exact build, vendor advisories, configuration, and applicable security patches.

Scenario 3: Misuse of Stolen Credentials

Credentials obtained through phishing, malware, or another compromised system may be used to attempt SSH access.

If the same password is reused across multiple services, a compromise elsewhere may affect the target server.

1.6.4 Security Measures for SSH

1. **Use strong authentication:** Require strong, unique credentials and prefer SSH public-key authentication or other appropriate secure mechanisms.
2. **Disable direct root login:** Require administrators to authenticate using approved individual accounts and use controlled privilege elevation.
3. **Restrict source addresses:** Allow SSH connections only from approved administrative networks, VPNs, or management hosts.
4. **Update SSH software:** Install supported releases and apply security patches promptly.
5. **Limit authentication attempts:** Use appropriate rate limiting or protective controls to reduce repeated login attempts.
6. **Protect private keys:** Store private keys securely, restrict their permissions, and revoke compromised keys.
7. **Monitor authentication logs:** Alert on repeated failures, unusual login times, unexpected source addresses, and suspicious administrative activity.
8. **Review user accounts:** Remove inactive accounts and restrict administrative privileges to authorized personnel.

9. **Use centralized access management:** Where appropriate, apply identity management, multi-factor authentication, and privileged access controls.
10. **Disable unnecessary SSH exposure:** If remote administration is not required, disable the service or close the associated port.

These measures reduce the likelihood that the SSH service will become an entry point for unauthorized access.

1.7 Detailed Analysis of HTTP – Port 80

1.7.1 Purpose of HTTP

HTTP is an application-layer protocol used by browsers and web applications to communicate with web servers. Port 80 is conventionally associated with HTTP traffic.

Web servers may provide websites, APIs, login portals, and business applications. Because these services often process user input and handle sensitive information, their configuration and application logic must be protected.

1.7.2 Security Risks Associated with HTTP

Unencrypted communication: Standard HTTP does not provide transport encryption. Sensitive information transmitted over an untrusted network may be exposed.

SQL injection: If an application incorporates untrusted input into database queries without proper protections, an attacker may manipulate the query.

Cross-site scripting: Improper handling of user-controlled content may allow malicious scripts to execute in another user's browser.

Broken access control: Weak authorization checks may allow users to access resources that they are not permitted to view or modify.

Security misconfiguration: Default settings, unnecessary features, directory listings, and verbose error messages may reveal information about the server.

Outdated components: Unsupported web server software, frameworks, libraries, or plugins may contain known vulnerabilities.

Session weaknesses: Inadequate session protection may increase the risk of session theft or unauthorized account access.

1.7.3 Possible Attack Scenarios

Scenario 1: Interception of Unencrypted Traffic

If an employee accesses a web application over HTTP through an untrusted network, a suitably positioned attacker may be able to observe the traffic.

If the application sends sensitive information without encryption, this could expose data such as session identifiers or form contents.

The risk depends on the network environment and the information transmitted.

Scenario 2: SQL Injection

A web application may accept information through search boxes, login forms, or URL parameters.

If the application builds database queries unsafely, specially crafted input may alter the intended query. Depending on the application's database permissions and protections, this could expose or modify records.

Scenario 3: Cross-Site Scripting

If a website displays user-controlled content without appropriate output encoding or sanitization, malicious scripts may execute in a victim's browser.

The impact may include unauthorized actions within the affected user's session, data exposure, or manipulation of displayed content.

Scenario 4: Information Disclosure

An improperly configured server may reveal directory contents, internal file paths, software versions, or detailed error messages.

Attackers can use such information to improve reconnaissance and identify additional weaknesses.

1.7.4 Security Measures for HTTP

1. **Enable HTTPS:** Configure a valid TLS certificate and redirect HTTP requests to HTTPS wherever appropriate.
2. **Protect sensitive information:** Do not transmit passwords, authentication tokens, or confidential information through unencrypted connections.
3. **Validate user input:** Apply appropriate server-side validation and use parameterized database queries.
4. **Prevent cross-site scripting:** Use context-appropriate output encoding, safe templating practices, and a suitable Content Security Policy.

5. **Implement access control:** Verify authorization on the server for every protected resource and sensitive action.
6. **Secure session management:** Use secure session identifiers and appropriate cookie attributes, including Secure and HttpOnly where applicable.
7. **Update software:** Maintain supported web server, framework, library, and application versions.
8. **Disable unnecessary features:** Remove default pages, unnecessary modules, and directory listings.
9. **Reduce information disclosure:** Avoid exposing detailed internal errors or unnecessary server information to users.
10. **Conduct security testing:** Use authorized vulnerability assessments and application security testing to identify weaknesses before deployment.

1.7.5 Importance of Web Application Security

Web application security requires more than enabling HTTPS. Transport encryption protects data in transit, but it does not correct application-level weaknesses such as SQL injection, broken access control, or insecure authentication.

Therefore, the organization should combine secure coding, regular patching, application testing, logging, access control, and transport encryption.

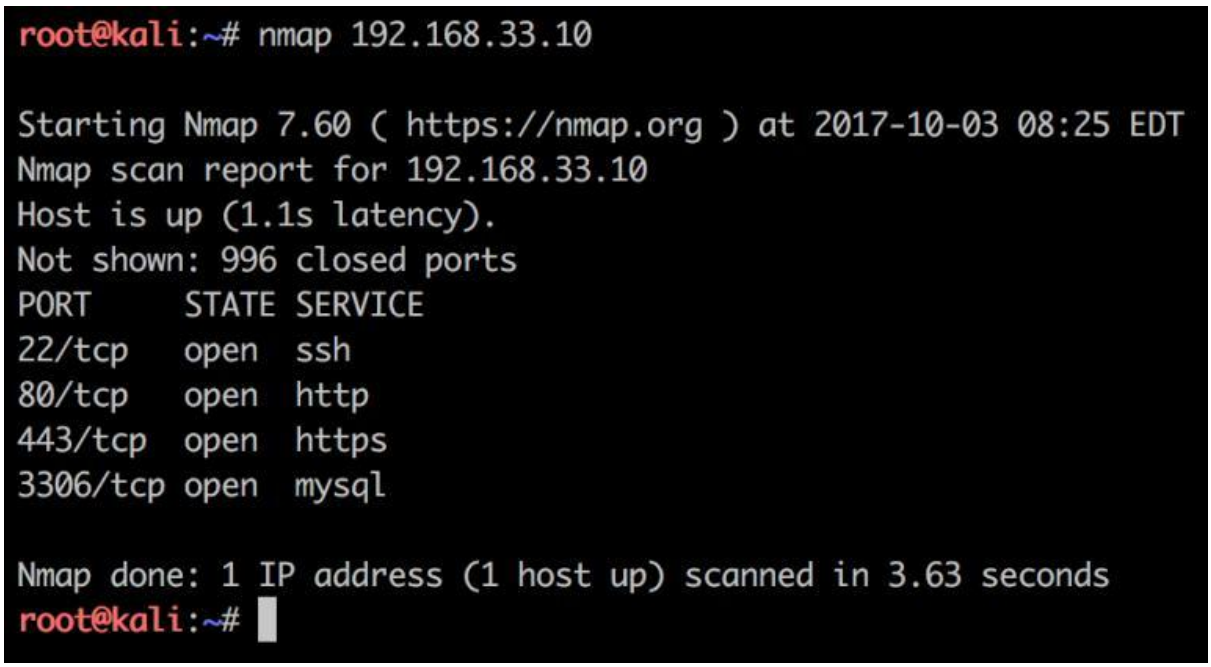


Figure 1.7: Sample Nmap Scan Output

1.8 Detailed Analysis of MySQL – Port 3306

1.8.1 Purpose of MySQL

MySQL is a relational database management system used to store and retrieve structured data. It is commonly used by web applications, business systems, content management platforms, and transaction-processing systems.

Database servers may contain confidential records and therefore require strong authentication, controlled access, secure communications, and reliable backup procedures.

1.8.2 Security Weaknesses Associated with MySQL

Unnecessary network exposure: A database service reachable from untrusted networks receives connection attempts from a wider range of potential attackers.

Weak credentials: Easily guessed passwords may allow unauthorized users to authenticate.

Excessive privileges: Accounts with unnecessary administrative rights can increase the impact of a compromise.

Outdated software: Unsupported database versions may contain known vulnerabilities.

Insecure communications: Without appropriate transport protection, database traffic may be exposed to interception in certain network environments.

Poor backup protection: Unencrypted or publicly accessible backups may expose sensitive data.

Insufficient auditing: Missing logs may delay the detection and investigation of unauthorized access.

1.8.3 Possible Attack Scenarios

Scenario 1: Unauthorized Database Login

An attacker who can reach the database service may attempt to authenticate using weak or compromised credentials.

If authentication succeeds, the attacker may read or modify records according to the permissions assigned to the compromised account.

Scenario 2: Abuse of Excessive Privileges

If an application account has administrative permissions when it only needs to read or update selected tables, compromising that account may allow a wider range of unauthorized actions.

The principle of least privilege helps reduce the potential damage.

Scenario 3: Exploitation of an Unpatched Database

An attacker may investigate whether the detected MySQL version is affected by a known security vulnerability.

If the vulnerability is applicable and the necessary conditions are satisfied, the attacker may attempt exploitation. The actual impact depends on the specific weakness, configuration, and privileges involved.

Scenario 4: Database Backup Exposure

Backups containing database records may be copied or accessed if they are stored in insecure locations.

An attacker who obtains an exposed backup may be able to retrieve confidential information without directly compromising the live database service.

1.8.4 Security Measures for MySQL

1. **Restrict network access:** Permit database connections only from approved application servers and administrative systems.
2. **Avoid public exposure:** Do not expose the database directly to the internet unless there is a documented, justified requirement and appropriate protective architecture.
3. **Use strong authentication:** Enforce strong credentials and appropriate account authentication mechanisms.
4. **Apply least privilege:** Grant each database account only the permissions needed for its assigned function.
5. **Remove unnecessary accounts:** Disable or remove unused accounts and review permissions regularly.
6. **Patch regularly:** Maintain supported MySQL versions and apply relevant security updates.
7. **Encrypt database connections:** Use TLS for database traffic when appropriate.
8. **Protect backups:** Encrypt backups, restrict access, and test recovery procedures.
9. **Enable auditing and monitoring:** Track authentication events, privilege changes, suspicious queries, and unexpected data access.
10. **Protect application credentials:** Store database secrets securely and avoid hardcoding passwords in publicly accessible source code.
11. **Test recovery procedures:** Maintain backups and verify that the organization can restore data following a security incident.

12. **Separate network roles:** Place the database in a protected network segment and limit communication with other systems.

1.9 Operating System and Service-Version Detection

The Nmap report also identifies operating system characteristics and service versions. This information is valuable during authorized security assessments because software versions help analysts determine whether a system is supported and whether applicable security updates are available.

1.9.1 Importance of Operating System Identification

Different operating systems have different security features, patching mechanisms, default configurations, and access-control models.

Identifying the operating system helps the analyst determine which security updates, configuration standards, and hardening practices apply to the target.

1.9.2 Risks of Outdated Versions

Older software may contain vulnerabilities that have been corrected in later releases. If an organization continues using unsupported versions, it may be unable to receive regular security patches.

Attackers may use publicly available vulnerability information to identify systems that require further investigation.

1.9.3 Recommended Measures

- Maintain an accurate inventory of operating systems and installed services.
- Use supported operating system and application versions.
- Apply security updates according to risk and organizational policy.
- Remove unnecessary software and services.
- Compare identified versions with vendor security advisories.
- Verify potential vulnerabilities before classifying them as confirmed findings.
- Restrict access to detailed infrastructure information.

Version detection is an important starting point, but it should not be treated as proof that a system is vulnerable.

1.10 Defense-in-Depth Strategy

Defense in depth is a cybersecurity approach that uses multiple layers of protection rather than relying on a single control.

For the target system, the following layers are recommended.

Network Layer

Use firewalls, network segmentation, and access-control rules to restrict connections to required services.

Host Layer

Apply operating system hardening, patch management, endpoint protection, and secure configuration standards.

Application Layer

Use secure coding practices, authentication, authorization, input validation, and regular application security testing.

Database Layer

Restrict database access, apply least privilege, encrypt sensitive data where appropriate, and protect backups.

Monitoring Layer

Collect system, authentication, application, and database logs. Monitor for suspicious behavior and establish incident response procedures.

1.11 Remediation Plan

Priority	Action	Expected Security Benefit
1	Verify whether MySQL exposure is necessary	Reduces unnecessary database access
2	Restrict SSH to authorized management systems	Reduces unauthorized login attempts
3	Enable HTTPS and secure the web application	Protects traffic and reduces application risk
4	Update the operating system and services	Addresses applicable known vulnerabilities
5	Enforce least privilege and strong authentication	Limits the impact of account compromise
6	Enable centralized logging and alerting	Improves detection and investigation

7	Conduct follow-up security testing	Confirms whether remediation was effective

The security team should document each finding, assign an owner, define a remediation deadline, and retest the affected service after changes are completed.

1.12 Conclusion

The Nmap scan of 192.168.1.10 identified SSH on port 22, HTTP on port 80, and MySQL on port 3306. These services provide useful functionality but can introduce security risks when improperly configured or unnecessarily exposed.

SSH requires strong authentication, restricted administrative access, and regular updates. HTTP requires transport encryption, secure application development, and appropriate access controls. MySQL requires network restrictions, least-privilege permissions, secure credentials, and protected backups.

Operating system and service-version detection can further help identify outdated software and guide vulnerability assessment. However, actual vulnerabilities must be verified before their severity is determined.

By combining network restrictions, secure configurations, patch management, monitoring, and regular authorized testing, the organization can reduce its attack surface and improve the confidentiality, integrity, and availability of its systems.

QUESTION 2: ANALYSIS OF GOPHISH PHISHING AWARENESS CAMPAIGN REPORT

2.1 Introduction

Social engineering is a cybersecurity technique in which attackers manipulate human behavior to obtain confidential information, gain unauthorized access, or persuade individuals to perform unsafe actions. Instead of relying only on technical vulnerabilities, social engineering exploits trust, urgency, curiosity, fear, and lack of awareness.

Phishing is one of the most common forms of social engineering. Attackers send deceptive emails or messages that appear to come from legitimate organizations, colleagues, service providers, or administrators. These messages may contain fraudulent links, fake login pages, or malicious attachments.

Phishing attacks can result in credential theft, malware infection, unauthorized account access, financial loss, and data breaches.

In the given scenario, ABC Technologies Pvt. Ltd. conducted a phishing awareness campaign using GoPhish. The report shows that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment.

These results suggest that the organization should improve employee awareness, strengthen email security, enforce appropriate authentication controls, and establish clear procedures for reporting suspicious messages.

2.2 Objectives of the Analysis

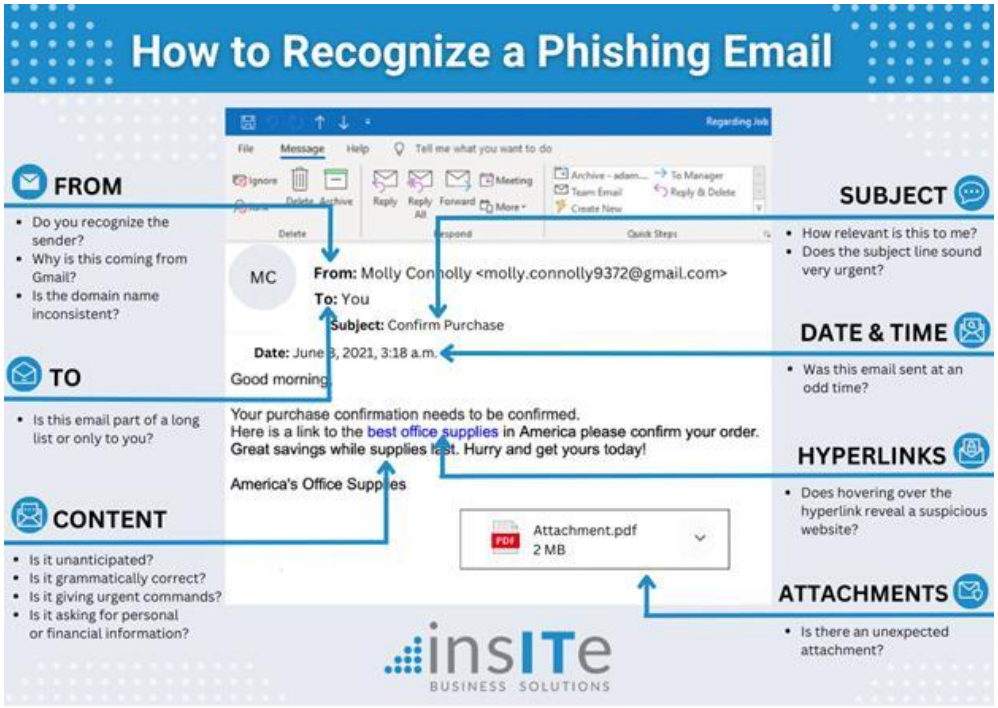


Figure 2.2: Common Phishing Indicators

The main objectives are:

1. To interpret the findings of the GoPhish campaign.
2. To identify employee behaviors that increase phishing risk.
3. To explain the possible consequences of credential submission and attachment downloads.
4. To recommend effective employee awareness programs.
5. To evaluate technical email security controls.
6. To recommend suitable organizational policies.
7. To develop an incident response and continuous improvement strategy.

2.3 Overview of GoPhish

GoPhish is an open-source framework used to conduct authorized phishing simulations and security awareness assessments.

Organizations can use it to create simulated phishing emails, manage test campaigns, direct participants to controlled landing pages, and review campaign results.

A properly authorized simulation helps measure how employees respond to realistic social engineering scenarios.

2.3.1 Major Features of GoPhish

Campaign management: Supports the organization and execution of phishing simulation campaigns.

Email templates: Allows security teams to prepare simulated email messages for approved tests.

Landing pages: Supports controlled web pages used to evaluate user interaction with simulated phishing content.

Campaign reporting: Helps summarize interactions such as email delivery, link clicks, and form submissions, depending on the campaign configuration.

Awareness evaluation: Provides information that can guide future training and security improvements.

2.3.2 Importance of Phishing Simulations

Employees are an important part of an organization's security defenses. Even when technical controls are available, a user may unintentionally expose credentials or download an unsafe file.

Phishing simulations allow organizations to evaluate awareness under controlled conditions. They also help identify common mistakes and measure whether training improves employee behavior.

However, campaign results should be interpreted carefully. A simulated click does not necessarily mean that a real attack would succeed, and downloading a simulated attachment does not prove that a real malicious file would execute successfully.

2.4 Analysis of Campaign Findings

The campaign produced three important findings.

Campaign Finding	Reported Result	Interpretation
Employees clicked the phishing link	40%	Many employees interacted with the simulated message

Employees entered login credentials	20%	Some employees submitted sensitive authentication information
Employees downloaded an attachment	Several users	Some employees interacted with a potentially dangerous file

The organization should examine these findings alongside the number of recipients, message delivery rate, campaign duration, and reporting rate.

The report does not specify the exact number of employees or whether the click and credential percentages use the same denominator. Therefore, the figures should be treated as reported campaign measurements rather than used to calculate an exact number of compromised accounts.

2.5 Analysis of the 40% Click Rate

A 40% click rate indicates that a substantial proportion of participating employees interacted with the simulated phishing link.

Clicking a link may result from several factors, including lack of awareness, trust in the sender, curiosity, time pressure, or failure to inspect the destination URL.

2.5.1 Possible Causes

Lack of sender verification: Employees may trust a message without checking the sender's full email address.

Urgency and fear: Messages claiming that an account will be suspended or a payment will fail may pressure employees to act quickly.

Familiar branding: Attackers may imitate familiar companies, internal departments, or common business applications.

Unclear URL destinations: Employees may click links without checking the domain or recognizing subtle spelling differences.

Excessive workload: Employees working under time pressure may pay less attention to unusual messages.

Limited training: Employees may not have received practical instruction on identifying suspicious links.

2.5.2 Security Implications

In a real phishing attack, clicking a malicious link may lead to a fraudulent login page, a malicious download, or a website attempting to exploit a browser vulnerability.

A click alone does not establish that the employee's device has been compromised. The consequences depend on the destination, the user's subsequent actions, the browser environment, and the technical protections in place.

Nevertheless, the reported click rate indicates that the organization should improve link recognition and verification behavior.

2.5.3 Recommended Improvements

Employees should be trained to inspect unexpected links, verify the sender through an independent channel, and avoid entering credentials after following suspicious links.

Email security systems should also inspect links, block known malicious destinations, and provide warnings when users visit potentially dangerous websites.

2.6 Analysis of the 20% Credential-Submission Rate

The report indicates that 20% of employees entered their login credentials on the simulated phishing page.

This is an important finding because passwords and authentication information protect email accounts, business applications, remote access systems, and sensitive organizational resources.

2.6.1 Why Employees Submit Credentials

Trust in the message: Employees may believe that the email comes from a legitimate organization or internal administrator.

Similarity to legitimate login pages: A fraudulent page may imitate the appearance of a familiar service.

Fear of account suspension: Employees may enter credentials to avoid losing access to an account.

Password reuse: Users may reuse passwords across several services, increasing the impact of a stolen password.

Insufficient authentication awareness: Employees may not understand that a legitimate service should not request credentials through an unexpected or suspicious link.

2.6.2 Potential Consequences

If credentials are stolen in a real attack, an attacker may attempt to access the associated account.

Depending on the permissions and additional security controls, compromised credentials could lead to:

- Unauthorized access to email or business applications.

- Exposure of confidential documents.
- Misuse of legitimate accounts to send further phishing messages.
- Attempts to reset other account passwords.
- Unauthorized access to sensitive organizational information.
- Additional attacks against connected systems.

The actual consequences depend on the account's privileges, whether the credentials are valid, and whether MFA or other security controls prevent unauthorized access.

2.6.3 Recommended Security Measures

1. Enforce multi-factor authentication for important systems.
2. Prefer phishing-resistant authentication, such as passkeys or FIDO2 security keys, where supported.
3. Prohibit password reuse and encourage unique passwords.
4. Provide a password manager where appropriate.
5. Educate employees not to enter credentials through unexpected email links.
6. Implement suspicious-login detection and risk-based authentication.
7. Provide a clear procedure for reporting suspected credential exposure.
8. Revoke sessions and reset credentials promptly when compromise is suspected.
9. Review account activity following a suspected phishing incident.
10. Apply least-privilege access to reduce the impact of account compromise.

2.7 Analysis of Malicious Attachment Downloads

The report also indicates that several users downloaded a malicious attachment.

Email attachments are frequently used in social engineering because users often expect to receive invoices, reports, meeting documents, purchase orders, or other business files.

An attacker may disguise a harmful file as a legitimate document or use a message that encourages the recipient to open it urgently.

2.7.1 Common Attachment Threats

Malicious executable files: Files designed to run unwanted or harmful programs.

Macro-enabled documents: Documents that may use embedded code or other features to perform unsafe actions when permitted by the user or system configuration.

Archive files: Compressed files that may contain dangerous content or disguise the true nature of their contents.

Exploited documents: Files that target vulnerabilities in document readers or other software.

Credential-harvesting documents: Files or linked content designed to persuade users to disclose authentication information.

2.7.2 Possible Consequences

If a malicious attachment is executed successfully, it may install malware, steal information, disrupt system operation, or establish unauthorized access.

In more serious cases, malware may attempt to spread to other systems or encrypt important files.

However, downloading an attachment does not automatically mean that malware executed or that the device was compromised. Security teams must investigate the file, its behavior, and the affected endpoint before determining the impact.

2.7.3 Recommended Preventive Measures

- Use email gateways that inspect attachments for known threats.
- Apply sandbox analysis to suspicious files where available.
- Block or restrict dangerous attachment types according to business requirements.
- Keep operating systems and document-processing applications updated.
- Disable unnecessary macros and other risky file features.
- Deploy endpoint protection and endpoint detection and response tools.
- Restrict local administrator privileges.
- Train employees to verify unexpected attachments before opening them.
- Maintain offline or otherwise protected backups.
- Establish procedures for isolating affected devices and investigating suspicious files.

2.8 Identification of Employee Security Weaknesses

The campaign highlights several possible weaknesses in employee security behavior.

2.8.1 Insufficient Phishing Recognition

Employees may not recognize suspicious email characteristics or may fail to verify sender identities and URLs.

2.8.2 Weak Credential Protection Practices

Credential submission suggests that some users may not distinguish between legitimate authentication requests and fraudulent login pages.

2.8.3 Unsafe File-Handling Behavior

Attachment downloads indicate that users may interact with unexpected files without adequate verification.

2.8.4 Inadequate Verification of Requests

Employees may act on requests without confirming them through a separate trusted communication channel.

2.8.5 Possible Lack of Reporting

The supplied report does not state how many employees reported the simulated phishing email. This measurement should be collected because prompt reporting can help the security team respond before other employees interact with a real attack.

2.9 User Awareness and Training Programs

Employee awareness should be continuous rather than limited to a single annual presentation.

2.9.1 Initial Cybersecurity Training

New employees should receive training on phishing, password security, MFA, data protection, suspicious attachments, and incident reporting.

2.9.2 Regular Awareness Sessions

Conduct periodic sessions that explain current social engineering methods and common warning signs.

Training should include examples relevant to the organization's actual business processes, such as invoices, HR notices, password-reset messages, and supplier communications.

2.9.3 Practical Workshops

Practical sessions should demonstrate how to:

- Inspect sender addresses.
- Identify suspicious domain names.

- Recognize unusual requests for credentials.
- Verify unexpected financial or administrative requests.
- Handle suspicious attachments safely.
- Report suspicious messages using approved tools.

2.9.4 Simulated Phishing Campaigns

Conduct periodic, authorized GoPhish campaigns with varied scenarios.

Provide immediate educational feedback to employees who interact with the simulation. Training should explain the warning signs that were missed and the safer action to take in the future.

2.9.5 Role-Based Training

Employees who handle financial transactions, customer information, administrative accounts, or sensitive documents may require additional training relevant to their responsibilities.

2.9.6 Positive Reporting Culture

Employees should be encouraged to report suspicious emails promptly, including cases where they may already have clicked a link or opened a file.

A supportive reporting culture improves incident response because employees are more likely to report mistakes before the consequences become more serious.

2.10 Technical Email Security Controls

2.10.1 Spam and Phishing Filtering

Email security gateways can inspect messages for suspicious sender information, malicious URLs, dangerous attachments, and impersonation attempts.

Filtering systems should be updated regularly and configured to reduce the delivery of known malicious messages.

2.10.2 SPF – Sender Policy Framework

SPF allows a domain owner to specify which mail servers are authorized to send messages for that domain.

Receiving mail systems can use SPF results as one signal when evaluating a message's authenticity.

SPF does not prove that the content of a message is safe, and it does not prevent every form of impersonation.

2.10.3 DKIM – DomainKeys Identified Mail

DKIM uses a cryptographic signature to help verify that signed portions of a message have not been altered and that the message is associated with a signing domain.

Receiving systems can validate the signature using the relevant public key.

DKIM is useful for email authentication, but a valid signature does not guarantee that the sender or message is trustworthy in every respect.

2.10.4 DMARC – Domain-based Message Authentication, Reporting and Conformance

DMARC builds on SPF and DKIM by checking domain alignment and allowing domain owners to publish policies for messages that fail authentication checks.

It also supports reporting that helps organizations understand how their domains are being used.

Organizations should deploy DMARC carefully, validate legitimate sending services, and strengthen enforcement as their email authentication configuration becomes reliable.

2.10.5 URL Protection

Email systems may inspect links against threat intelligence sources, analyze suspicious destinations, and block access to known malicious websites.

Time-of-click protection can help detect threats that become known after a message has been delivered.

2.10.6 Attachment Sandboxing

Sandboxing evaluates suspicious files in an isolated environment to identify potentially harmful behavior.

This can improve detection of previously unknown threats, although no single analysis technique can identify every malicious file.

2.10.7 Multi-Factor Authentication

MFA requires an additional authentication factor beyond a password.

It reduces the risk associated with stolen passwords. Phishing-resistant MFA is preferable where available because some weaker MFA methods can still be intercepted or manipulated through sophisticated phishing attacks.

2.10.8 Endpoint Detection and Response

Endpoint security tools can identify suspicious process activity, malicious file behavior, unauthorized changes, and other indicators of compromise.

These tools complement email security because some threats may pass through email filters or arrive through other channels.

2.11 Organizational Policies

ABC Technologies Pvt. Ltd. should establish clear policies that define employee responsibilities and the organization's response to phishing incidents.

Email Security Policy

The policy should explain how employees must handle unexpected emails, suspicious links, attachments, and requests for confidential information.

Password and Authentication Policy

The policy should require unique credentials, appropriate MFA, secure password storage, and prompt reporting of suspected credential theft.

Acceptable Use Policy

The policy should define appropriate use of company devices, email, web services, and organizational data.

Incident Reporting Policy

Employees should know how to report suspicious emails, suspected malware, lost devices, and compromised accounts.

Access Control Policy

Employees should receive only the access needed for their roles. Administrative privileges should be restricted and reviewed regularly.

Vendor and Payment Verification Policy

Requests involving payments, bank account changes, confidential information, or unusual supplier instructions should be verified through a separate, trusted communication channel.

Data Protection Policy

The organization should define how confidential information is stored, shared, transmitted, and disposed of.

2.12 Incident Response Procedure

If an actual phishing attack is suspected, ABC Technologies Pvt. Ltd. should follow a structured incident response process.

Step 1: Identification

Determine which users received the message and whether anyone clicked the link, submitted credentials, downloaded a file, or executed an attachment.

Step 2: Containment

Block malicious URLs and sender indicators where appropriate. Isolate affected endpoints if malware execution or other compromise is suspected.

Step 3: Credential Protection

If credentials may have been exposed, reset affected passwords, revoke active sessions, and review authentication activity.

Step 4: Investigation

Examine email logs, authentication records, endpoint alerts, and suspicious network activity to determine the scope of the incident.

Step 5: Eradication

Remove malicious files, eliminate unauthorized access, correct the affected configuration, and address the weakness that allowed the incident.

Step 6: Recovery

Restore affected systems from trusted sources when necessary and confirm that security controls are functioning correctly.

Step 7: Lessons Learned

Document the incident, identify improvement opportunities, update detection rules, and provide additional training where required.

2.13 Measurement and Continuous Improvement

The organization should use campaign metrics to evaluate whether its security program is improving.

Metric	Purpose
Email delivery rate	Measures how many campaign messages reached recipients
Link-click rate	Measures interaction with simulated phishing links
Credential-submission rate	Measures submission of information to simulated login pages

Attachment interaction rate	Measures interaction with simulated attachments
Reporting rate	Measures how frequently employees report suspicious messages
Time to report	Measures how quickly suspicious messages are reported
Repeat interaction rate	Helps identify where additional training may be useful

Metrics should be calculated using clearly defined denominators. For example, a click rate may be measured against delivered emails, while another organization may calculate it against all recipients. The definitions must remain consistent when comparing campaigns.

The organization should evaluate trends over time rather than relying on one campaign. A decrease in risky interactions and an increase in timely reporting may indicate improved awareness, although technical controls and campaign design should also be considered.

2.14 Recommended Improvement Plan

Immediate actions: Review whether any real incidents occurred, strengthen email filtering, confirm MFA coverage, and provide feedback to employees involved in the simulation.

Short-term actions: Conduct targeted awareness sessions, review sender authentication configuration, implement appropriate URL and attachment protection, and establish a clear reporting process.

Long-term actions: Repeat authorized phishing simulations, improve incident response exercises, assess authentication and endpoint controls, and review campaign results regularly.

2.15 Conclusion

The GoPhish campaign at ABC Technologies Pvt. Ltd. identified weaknesses in phishing recognition, credential protection, and attachment handling. The reported 40% click rate, 20% credential-submission rate, and attachment downloads indicate that employees may be vulnerable to deceptive messages.

The organization should implement regular awareness training, realistic phishing simulations, secure email filtering, SPF, DKIM, DMARC, multi-factor authentication, endpoint protection, and clear incident response procedures.

Technical controls and employee education should operate together. Employees should be encouraged to verify suspicious requests, avoid submitting credentials through unexpected links, and report potentially harmful messages promptly.

By measuring campaign results consistently and improving controls over time, ABC Technologies Pvt. Ltd. can reduce the likelihood and impact of successful social engineering attacks.

QUESTION 3: ANALYSIS OF DNS ZONE TRANSFER REPORT USING DIG

3.1 Introduction

The Domain Name System (DNS) is a fundamental component of the internet and organizational networks. It translates human-readable domain names into IP addresses and provides information needed to locate services such as websites, mail servers, and other network resources.

Organizations depend on DNS for website access, email delivery, service discovery, and internal network operations. Incorrectly configured DNS infrastructure may reveal information about an organization's systems or interfere with the availability and integrity of its services.

In the given scenario, a DNS assessment performed using the dig tool identified a DNS server that permits a successful zone transfer through AXFR. The transfer exposes internal hostnames, mail servers, and other DNS records.

This finding raises concerns about unauthorized information disclosure. An attacker who obtains the records may use them to improve reconnaissance, identify potential targets, and plan further attacks.

3.2 Objectives of the Analysis

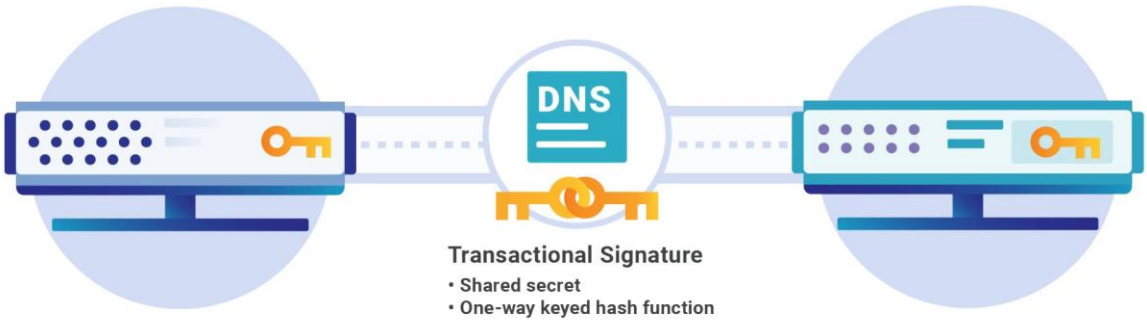


Figure 3.2: Secure DNS Zone Transfer Architecture

The objectives are:

1. To understand DNS architecture and the purpose of DNS records.
2. To explain DNS zone transfers and the AXFR mechanism.
3. To interpret the findings of the DNS assessment.

4. To identify security risks associated with unauthorized zone transfers.
5. To explain how exposed DNS information may support reconnaissance.
6. To recommend secure DNS configuration practices.
7. To describe verification, monitoring, and remediation procedures.

3.3 Overview of DNS

DNS is a distributed naming system that maps domain names to information required by network applications.

For example, when a user enters a website name in a browser, the system uses DNS resolution to discover the corresponding network address or other required records.

DNS is organized hierarchically. Different DNS servers are responsible for different zones, and authoritative servers provide the records for the zones they manage.

3.3.1 Important DNS Components

DNS resolver: Receives queries from clients and performs or coordinates the resolution process.

Root name servers: Help direct queries toward the appropriate top-level domain servers.

Top-level domain servers: Provide information about authoritative servers for domains under a particular top-level domain.

Authoritative DNS servers: Provide the records for the zones they manage.

Primary DNS server: Holds the authoritative zone data used as the source for updates and distribution in a conventional primary-secondary configuration.

Secondary DNS server: Maintains a copy of a zone obtained from an authorized primary server or another approved source.

3.3.2 Importance of DNS Security

DNS supports many critical organizational functions. If DNS is misconfigured or compromised, users may be unable to reach legitimate services, or they may be directed toward incorrect destinations.

DNS security therefore requires appropriate access control, accurate records, secure administration, monitoring, and reliable backup procedures.

3.4 Common DNS Record Types

Record Type	Purpose

A	Maps a hostname to an IPv4 address
AAAA	Maps a hostname to an IPv6 address
MX	Identifies mail servers for a domain
CNAME	Defines an alias for another hostname
NS	Identifies authoritative name servers
TXT	Stores text data, often used for verification and email security
PTR	Supports reverse DNS lookups
SOA	Contains administrative information about a DNS zone
SRV	Identifies servers providing particular services

A zone transfer may expose multiple record types, depending on the zone's contents.

Not every DNS record is confidential. Public websites and mail servers are expected to have publicly accessible DNS information. The concern in this scenario is the unauthorized disclosure of the complete zone, particularly records that reveal internal infrastructure or services that should not be publicly documented.

3.5 DNS Zone Transfer Fundamentals

A DNS zone is a collection of records managed as a unit within the DNS hierarchy.

A zone transfer copies zone data from one DNS server to another. It is commonly used to synchronize authoritative DNS servers.

3.5.1 AXFR

AXFR is the DNS protocol mechanism used to request a full zone transfer.

When an authorized secondary DNS server needs a copy of the zone, it can request the records from the primary server. The transfer allows the secondary server to maintain an accurate copy of the zone.

Zone transfers are legitimate and necessary in many DNS deployments. They become a security concern when a server permits unauthorized clients to retrieve information that should be restricted.

3.5.2 IXFR

IXFR is a mechanism for transferring incremental zone changes rather than retransmitting the entire zone in every case.

It can reduce the amount of information transferred when only a limited number of records have changed.

Both AXFR and IXFR should be configured so that only authorized systems can obtain the zone data.

3.6 Overview of the Dig Tool

dig, which stands for Domain Information Groper, is a command-line utility used to query DNS servers and examine DNS responses.

It is widely used by system administrators, network engineers, and security analysts to troubleshoot DNS configuration and investigate DNS behavior.

3.6.1 Major Uses of Dig

- Query DNS records.
- Inspect A, AAAA, MX, NS, TXT, and other record types.
- Identify authoritative name servers.
- Examine DNS responses and response codes.
- Investigate DNS resolution problems.
- Test authorized zone-transfer configuration.
- Validate DNS records following configuration changes.

3.6.2 Importance in Ethical Hacking

During an authorized security assessment, dig helps identify DNS configuration weaknesses and excessive information exposure.

Security analysts can use it to confirm whether a zone transfer is restricted to approved servers and whether DNS records reveal information that should remain internal.

The tool itself does not compromise a DNS server. It sends DNS queries and displays the responses received.

3.7 Analysis of the Report Findings

The assessment report states that the DNS server permits a successful AXFR request and exposes internal hostnames, mail servers, and other DNS records.

This suggests that the server may not be restricting zone transfers to authorized secondary DNS servers.

3.7.1 Exposure of Internal Hostnames

Hostnames sometimes reveal the function of a system. Examples include names suggesting database servers, development systems, administrative interfaces, or backup infrastructure.

Such naming conventions may provide clues about an organization's environment.

3.7.2 Exposure of Mail Servers

MX records identify mail servers responsible for receiving email for a domain.

Mail server information is often public by design. However, when combined with other records, it may help an attacker understand the organization's email infrastructure and plan more targeted attacks.

3.7.3 Exposure of Additional DNS Records

A complete zone may reveal IP addresses, aliases, authoritative name servers, service records, and other information.

The extent of exposure depends on the actual records present in the zone. The report does not provide the exact record list, so the precise sensitivity of individual entries cannot be determined from the supplied information alone.

3.8 Security Implications of Unauthorized Zone Transfers

3.8.1 Information Disclosure

The primary concern is that an unauthorized party can obtain a structured collection of DNS records.

Instead of discovering hostnames individually, the party may receive many records in a single transfer.

Security impact: This may reduce the time and effort required for reconnaissance and expose details that the organization did not intend to make available to arbitrary clients.

3.8.2 Infrastructure Mapping

DNS records can help an attacker identify systems associated with different organizational functions.

For example, a naming convention may indicate that a particular host provides database services or administrative access.

Security impact: This information can help prioritize further investigation and identify systems that warrant additional security review.

3.8.3 Improved Targeted Phishing

Hostnames, service names, and mail infrastructure information may help attackers create more convincing messages.

For example, an attacker may use the name of a known internal application to create a deceptive message that appears relevant to employees.

Security impact: The information may increase the credibility of targeted social engineering attempts.

3.8.4 Identification of Potentially Exposed Services

DNS records may point to hosts associated with remote access, web applications, development environments, or other services.

Security impact: An attacker may investigate whether any identified services are reachable and vulnerable. The DNS records themselves do not prove that the services are accessible from the internet.

3.8.5 Exposure of Naming Conventions

Consistent hostnames can reveal patterns in how systems are named and grouped.

Security impact: This may help attackers infer system roles or create more convincing impersonation attempts.

3.8.6 Increased Risk When Combined with Other Information

DNS records may be combined with publicly available websites, certificate information, public documents, and other legitimate sources of information.

Security impact: Combining these sources may reveal a more complete picture of the organization's infrastructure than any single source provides.

3.9 Possible Attack Scenarios

Scenario 1: Reconnaissance Using Exposed Records

An attacker obtains a complete DNS zone and reviews the records for hostnames that indicate important systems.

The attacker then uses the information to determine which systems warrant additional security investigation.

Preventive measure: Restrict zone transfers to authorized secondary DNS servers and avoid exposing unnecessary internal records.

Scenario 2: Targeted Phishing

An attacker discovers hostnames associated with internal applications or administrative services and uses that information to create deceptive messages.

Employees may be more likely to trust a message that refers to a familiar application or service.

Preventive measure: Provide phishing awareness training, implement email authentication, and encourage independent verification of unexpected requests.

Scenario 3: Investigation of Potentially Vulnerable Services

An attacker identifies DNS records associated with a particular service and investigates whether the service is exposed or contains known vulnerabilities.

The attack would require additional conditions, such as network reachability and an applicable weakness.

Preventive measure: Restrict network access, patch exposed systems, and perform regular authorized vulnerability assessments.

Scenario 4: Discovery of Forgotten Systems

Old DNS records may reveal systems that are no longer actively managed but remain documented in the zone.

If a record points to a resource that has been abandoned or misconfigured, it may warrant investigation for security risks.

Preventive measure: Audit DNS records regularly and remove obsolete entries after confirming that they are no longer required.

3.10 Recommended DNS Security Measures

3.10.1 Restrict AXFR to Authorized Servers

The most important corrective action is to configure the authoritative DNS server to allow zone transfers only from explicitly approved secondary DNS servers.

All other clients should be denied zone-transfer access.

This control directly addresses the issue identified in the report.

3.10.2 Use TSIG Authentication

Transaction Signature (TSIG) provides a mechanism for authenticating DNS messages between systems that support it.

It is commonly used to authenticate communications involving zone transfers between authorized DNS servers.

TSIG keys should be generated securely, stored safely, rotated according to policy, and protected against unauthorized access.

TSIG complements access restrictions rather than replacing the need for appropriate network and server configuration.

3.10.3 Separate Internal and External DNS

Organizations should maintain appropriate separation between internal DNS information and publicly accessible DNS zones.

Internal zones may contain names and records needed only by employees, internal applications, or private infrastructure.

External DNS zones should contain only the records required for public-facing services.

This separation reduces the risk of unintentionally exposing internal naming information through public DNS infrastructure.

3.10.4 Apply Firewall Rules

Network firewalls should permit DNS traffic required for legitimate operations and restrict administrative access to approved systems.

Zone-transfer requests should be limited to the authorized primary-secondary server relationships.

Firewall rules should be tested carefully to avoid disrupting legitimate DNS resolution and synchronization.

3.10.5 Secure DNS Server Configuration

DNS servers should run supported software versions and receive regular security updates.

Unnecessary features and services should be disabled, administrative access should be restricted, and configuration files should be protected against unauthorized modification.

3.10.6 Minimize Unnecessary Records

DNS administrators should remove obsolete records after confirming that they are no longer needed.

They should also avoid placing sensitive internal information in publicly accessible zones unless there is a clear operational requirement.

Record minimization does not replace AXFR restrictions, but it can reduce unnecessary information exposure.

3.10.7 Protect DNS Administration

Administrative accounts should use strong authentication and appropriate privileges.

Configuration changes should be authorized, logged, and reviewed. Where possible, DNS administration should be performed through a controlled management network.

3.10.8 Enable Logging and Monitoring

DNS servers should log relevant events, including zone-transfer requests and administrative changes.

Security teams should investigate repeated unauthorized AXFR requests, unusual query patterns, and unexpected changes to important records.

Monitoring helps identify attempts to retrieve restricted information and supports incident investigation.

3.11 Verification and Remediation Process

Corrective measures should be verified rather than assumed to be effective.

Step 1: Review the Current Configuration

The DNS administrator should identify the affected zone, the authoritative server, the configured secondary servers, and the current zone-transfer policy.

Step 2: Identify Authorized Secondary Servers

Create an accurate list of systems that require zone-transfer access. Confirm that each system is legitimate and appropriately managed.

Step 3: Restrict Zone Transfers

Update the DNS configuration so that only approved secondary servers can obtain the zone data.

Step 4: Configure Authentication

Where supported and appropriate, configure TSIG or another suitable mechanism to authenticate authorized zone-transfer communications.

Step 5: Review DNS Exposure

Inspect internal and external zones and remove obsolete records after validating that they are not required.

Step 6: Test the Configuration

An authorized security analyst should verify that an unauthorized client cannot obtain the zone and that approved secondary servers can still synchronize correctly.

Step 7: Monitor the Results

Review DNS logs and alerts to confirm that unauthorized transfer attempts are denied and legitimate DNS operations continue to function.

Step 8: Document the Remediation

Record the original finding, changes made, verification results, and any remaining risks.

3.12 DNS Security Best Practices

The following best practices should be maintained as part of the organization's routine security operations:

1. Restrict AXFR and IXFR operations to authorized systems.
2. Use TSIG where supported and appropriate.
3. Separate internal and external DNS zones.
4. Keep DNS software updated.
5. Protect administrative accounts and configuration files.
6. Apply firewall rules to control DNS management traffic.
7. Remove obsolete DNS records.
8. Monitor zone-transfer attempts and configuration changes.
9. Maintain reliable DNS backups and recovery procedures.
10. Perform periodic DNS security audits.
11. Review third-party DNS hosting and administrative permissions.
12. Document changes and verify that security controls work as intended.

3.13 Risk Assessment

Finding	Potential Risk	Recommended Priority
Unauthorized AXFR succeeds	Full-zone information disclosure	High if the zone contains sensitive records
Internal hostnames are exposed	Improved infrastructure reconnaissance	Depends on record sensitivity
Mail server records are exposed	Additional information for targeted attacks	Usually lower by itself; assess in context

Obsolete records remain in the zone	May reveal outdated infrastructure or point to mismanaged resources	Depends on the affected records
DNS activity is not monitored	Delayed detection of unauthorized requests	Medium to High depending on exposure

These priorities are preliminary and should be adjusted according to the sensitivity of the zone, network exposure, and the organization's threat model.

3.14 Organizational Benefits of DNS Security

Securing DNS infrastructure provides several benefits.

Improved confidentiality: Restricting unauthorized zone transfers helps prevent unnecessary disclosure of internal naming information.

Reduced reconnaissance opportunities: Limiting access to complete zone data makes it harder for unauthorized parties to obtain a structured inventory of the organization's DNS records.

Improved operational reliability: Proper configuration, monitoring, and backups support dependable DNS operations.

Better incident detection: Logging and alerts help administrators identify suspicious activity and investigate configuration changes.

Improved compliance and governance: Documented access controls and regular audits support security policies and risk-management requirements.

```
┌──(root💀kali)-[~]
└─# dig axfr test.lab @10.1.4.10

; <<>> DiG 9.16.8-Debian <<>> axfr test.lab @10.1.4.10
;; global options: +cmd
test.lab.               21600   IN      SOA     test.lab. ns1.test.lab. 101 5 30 21600 60
test.lab.               21600   IN      A       10.1.0.4
test.lab.               21600   IN      NS      ns1.test.lab.
test.lab.               21600   IN      NS      ns2.test.lab.
_kerberos._tcp.dc._msdcs.test.lab. 21600 IN SRV 0 0 88 test.lab.
_ldap._tcp.dc._msdcs.test.lab. 21600 IN SRV     0 0 389 test.lab.
gc._msdcs.test.lab.     21600   IN      A       10.1.0.4
_ldap._tcp.gc._msdcs.test.lab. 21600 IN SRV     0 0 3268 test.lab.
_kerberos._tcp.test.lab. 21600  IN      SRV     0 0 88 test.lab.
_kpasswd._tcp.test.lab. 21600   IN      SRV     0 0 464 test.lab.
_ldap._tcp.test.lab.    21600   IN      SRV     0 0 389 test.lab.
_kerberos._udp.test.lab. 21600  IN      SRV     0 0 88 test.lab.
_kpasswd._udp.test.lab. 21600   IN      SRV     0 0 464 test.lab.
api.test.lab.           21600   IN      A       10.0.4.11
bugtracker.test.lab.    21600   IN      A       10.0.4.3
dc.test.lab.            21600   IN      A       10.1.0.4
dns.test.lab.           21600   IN      A       10.0.4.10
dns.test.lab.           21600   IN      A       10.1.4.10
_ldap._tcp.ForestDnsZones.test.lab. 21600 IN SRV 0 0 389 test.lab.
itnews.test.lab.        21600   IN      A       10.0.4.4
news.test.lab.          21600   IN      A       10.0.4.12
ns1.test.lab.           21600   IN      A       10.1.4.10
ns2.test.lab.           21600   IN      A       10.0.4.10
site.test.lab.          21600   IN      A       10.0.4.2
token-SDS34gs93.test.lab. 21600 IN      A       127.0.0.1
vpn-1.test.lab.         21600   IN      A       172.16.50.11
test.lab.               21600   IN      SOA     test.lab. ns1.test.lab. 101 5 30 21600 60
;; Query time: 147 msec
;; SERVER: 10.1.4.10#53(10.1.4.10)
;; WHEN: Tue Mar 16 09:26:55 EDT 2021
;; XFR size: 27 records (messages 1, bytes 835)
```

Figure 3.14: Sample DNS AXFR Output

3.15 Conclusion

The DNS assessment identified a potential information disclosure weakness because the organization's DNS server permitted a successful AXFR request. The transfer exposed internal hostnames, mail servers, and other DNS records.

Unauthorized zone transfers may help attackers perform reconnaissance, identify systems of interest, and prepare targeted social engineering attempts. However, the exposed information does not automatically grant access to the listed systems or prove that they are vulnerable.

The organization should restrict zone transfers to authorized secondary DNS servers, use TSIG where appropriate, separate internal and external DNS zones, apply firewall controls, update DNS software, and monitor suspicious requests.

Regular DNS audits and post-remediation testing are essential to verify that the weakness has been corrected without disrupting legitimate DNS operations.

OVERALL CONCLUSION

The three assessment scenarios demonstrate how ethical hacking techniques help organizations identify security weaknesses before malicious attackers can exploit them.

The Nmap report revealed network-accessible SSH, HTTP, and MySQL services. Each service provides important functionality but requires appropriate access controls, secure configuration, software maintenance, and monitoring.

The GoPhish campaign at ABC Technologies Pvt. Ltd. demonstrated that employee interaction with phishing links, submission of credentials, and attachment downloads may increase the likelihood of successful social engineering attacks. Regular awareness training, email security controls, phishing-resistant authentication, and effective incident response procedures can reduce these risks.

The DNS assessment demonstrated that an improperly restricted zone transfer may disclose infrastructure information that supports unauthorized reconnaissance. Restricting AXFR, authenticating authorized transfers, separating internal and external DNS, and monitoring DNS activity can reduce the risk.

Overall, effective cybersecurity requires a combination of technical safeguards, user awareness, secure administration, risk assessment, and continuous improvement. Ethical hacking supports this process by identifying weaknesses, validating security controls, and recommending practical corrective measures.

Organizations should conduct all scanning, testing, and simulation activities with proper authorization and within a clearly defined scope. By implementing the recommended measures, organizations can strengthen their security posture and better protect the confidentiality, integrity, and availability of their information systems.

CODE OF CONDUCT

I K. Sri Lasya (192472216) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: K. Sri Lasya